

School App — Major Issues Report

Role-based codebase analysis · Owner / Principal / Teacher / Guardian · 11 June 2026

Scope: full repository on **main** (~88,000 lines of Dart across 89 screens, 35 services, Firestore + Storage rules, 12 Cloud Functions). This report lists what is **still open**. Findings were verified against the current code, not copied from earlier review documents — a large number of previously reported issues are confirmed fixed and are summarised first.

Confirmed already resolved (verified in current code)

Firestore App Check (Play Integrity / App Attest) · Crashlytics crash reporting · server-side audit-log writer with client create denied and append-only rules · fee pre-aggregation (one read per class, not per student) · over-payment cap with explicit override · atomic gapless receipt numbering · payment reversal kept as void (never hard-deleted) with reconciliation view · installment-sum-equals-annual-fee validation · attendance lock/cutoff for historical dates · exam publish gate (guardians see results only after publishedAt) · report-card maxMarks>0 guard · Storage rules tenant-scoped via schoolId custom claims · friendly auth errors (no raw message leak) · multi-child guardian switcher · student leave approval auto-marks attendance · holiday calendar service · i18n on 82 of 89 screens · zero raw Color(0x...) literals · 12 unit-test files + Firestore rules test suites · purgeOldData retention callable · homework/leave body length caps · WhatsApp-enabled setting honoured at buttons · password-reuse / email-hijack prevention on user recreation.

How to read this report

CRITICAL = fix before relying on the app in production · **HIGH** = significant money/safety/usability risk · **MEDIUM** = real but containable · **LOW** = polish/backlog. Items marked (*verify*) could not be fully confirmed from code alone and need a quick manual check.

A. Platform & operations (affects every role)

#	Severity	Issue
1	CRITICAL	Deployed rules/functions may not match the repository The hardened firestore.rules, storage.rules and functions/index.js exist locally, but session records indicate they have not all been deployed to project attendanceapp-e76e1. Until deployed, production runs on the OLD rules — every security fix in the repo is inert. Storage rules additionally have a hard deploy-order dependency: run the claims backfill script and deploy syncUserClaims BEFORE the storage rules, or every user is locked out of Storage.
2	CRITICAL	Single Firebase project for development and production firebase_options.dart points only at attendanceapp-e76e1; no staging project or build flavors. Every test run, rules experiment and migration rehearses directly against live school data. One bad write or rules deploy hits real students. Create a separate staging project and a flavor/dart-define switch.
3	HIGH	No CI pipeline No .github/workflows (or equivalent). flutter analyze, the 12 unit-test files and the Firestore rules test suites all exist but nothing runs them automatically — a regression reaches main and deploy unchecked. A 30-line GitHub Action (analyze + test + rules tests) closes this.
4	HIGH	Root-admin trust anchored to two hardcoded Gmail addresses mandvishal@gmail.com / admin@schoolapp.org are literal strings in auth_service.dart, functions/index.js, firestore.rules and storage.rules. The app side now has a bootstrap-config fallback, but the rules files still hardcode them: compromise of either mailbox owns every school, and rotation requires a coordinated 4-file redeploy.
5	HIGH	Notification tap does nothing useful No onMessageOpenedApp / getInitialMessage handler exists. Push notifications deliver, but tapping one opens the app at the splash/dashboard root instead of the announcement, leave request or fee reminder it announced. This halves the value of the entire push pipeline for every role.

#	Severity	Issue
6	HIGH	All Cloud Functions in us-central1 Every callable and trigger is pinned to us-central1 while the user base is in India — 250–400 ms extra latency on every OTP, user-create, audit write and push fan-out. Move to asia-south1 (Mumbai).
7	MEDIUM	19 silent catch () {} blocks remain Across 9 files including fee_service, push_service, timetable_service, leaderboard_service and 4 screens. A failed fee-summary update or push-token sync looks identical to success. Each should at least log to Crashlytics.
8	MEDIUM	Two parallel task systems still wired task_service (class tasks) and staff_task_service coexist with separate screens, rules and inboxes. Staff see two task lists; every rules/feature change must be done twice. Pick one and migrate.
9	MEDIUM	Notification unread state is per-device Unread tracking is a SharedPreferences timestamp: reinstalling or switching phones marks everything unread; reading on one device clears nothing elsewhere. Needs a per-user lastSeen in Firestore.
10	MEDIUM	Stale-session edge cases (a) Dismissed/suspended staff keep cached offline access for up to 7 days (splash revalidation passes when the allowed_users read throws offline). (b) The 7-day window trusts the device clock — rolling the clock back defeats it. (c) Phone-OTP guardians are never revalidated on resume (no email key), so a revoked guardian keeps a broken dashboard until timeout.
11	MEDIUM	Multi-tenancy fallbacks are landmines Multi-school support is consciously deferred, but eight call sites still silently fall back to '?? school_1' (owner_principal_home ×4, auth_service, student_service, push_service, admin_login_screen). The day a second school onboard, any missed session-restore path quietly writes into school_1's data. Replace fallbacks with a loud throw.
12	MEDIUM	No EXIF stripping on image uploads Teacher/policy/logo photos are compressed but EXIF (incl. GPS location) is not stripped — location metadata of whoever took the photo can leak to anyone in the school who can view it.
13	MEDIUM	No biometric / app-lock option Staff phones holding the PII of hundreds of children rely only on the OS lock screen; no local_auth in pubspec. An optional PIN/biometric gate on app open is cheap insurance.
14	LOW	No force-upgrade / minimum-version gate Old builds that pre-date schoolId-filtered rules will hit permission-denied with no explanation once new rules deploy. A remote min-version check with an upgrade screen prevents support chaos.
15	LOW	No about / version / support screen No in-app way to see the app version, contact support, or report a problem — every issue becomes a phone call.
16	LOW	Email-keyed accounts cannot change email allowed_users docs are keyed by lowercased email; a legitimate email change orphans the account (history, role, classIds) since the doc ID cannot change.

B. Owner perspective — money, fraud & oversight

The owner's core question is "where is my money and is anyone stealing it?" The fee module records income well (integer paise, gapless receipts, reversal audit) but the surrounding controls are missing.

#	Severity	Issue
1	HIGH	No expense tracking — income-only books fees captures collections but there is no expense side at all, so no P&L, no monthly net position. The owner still runs the school's actual finances in a paper ledger or Excel; the app sees half the picture.
2	HIGH	No daily cash reconciliation per collector Payments record who collected, but there is no end-of-day "collected vs deposited" confirmation loop. The classic school fraud — cash collected, receipt issued, money pocketed for weeks — is invisible. Mostly a grouping query over data already stored.

#	Severity	Issue
3	MEDIUM	No concession / scholarship / sibling-discount support Fee structure is class-level with only a raw per-student feeAmount override. Discounts are therefore handled off-book with no record of who granted what to whom — the second classic leakage point after cash handling.
4	MEDIUM	No fee-structure versioning saveFeeStructure validates installment sums but overwrites in place. A mid-year revision destroys the schedule that earlier receipts were issued against — an auditor cannot reconstruct what was owed in July.
5	MEDIUM	No dues aging / projected cash-flow view Installment due dates are stored but never aggregated into "expected collections next 30/60/90 days" or an overdue-aging report. The owner cannot see a cash crunch coming.
6	MEDIUM	Owner screens are the i18n hole Of the 7 screens still hardcoded English, the owner's are most of them: owner_home, owner_principal_home, staff_directory_helpers, plus teacher_management and timetable_settings. A Hindi-first owner gets English exactly where money decisions happen.
7	MEDIUM	No full data export / backup Beyond per-feature CSVs there is no "download my school" dump (students, fees, attendance, marks). Owners fear vendor lock-in; a JSON/CSV export is also the DPDP-friendly answer to "give me my data".
8	LOW	No staff attendance or payroll trace Teacher presence is only inferable from leave applications; there is no check-in record, so the owner cannot verify the punctuality of the people they pay.
9	LOW	No per-school branding Logo upload exists in Storage paths but receipts/report cards/PDFs render generic branding — matters the moment a second school onboards.

C. Principal perspective — academics & staff oversight

#	Severity	Issue
1	HIGH	Analytics has no exam-results dimension analytics_screen covers attendance and fees only (confirmed gap). Pass percentage, subject averages, below-40% counts, class comparisons — the principal's core academic questions — are unanswerable in-app even though every mark is already in Firestore.
2	MEDIUM	No teacher compliance scorecard "Did 7-B's teacher mark attendance today? Post homework this week? Enter marks before the deadline?" Every one of these is a timestamp already stored, but nothing aggregates them, so the principal still chases teachers verbally.
3	MEDIUM	No teacher workload / substitution-load report Periods per week and substitution counts exist in the timetable and substitution history, but no view shows which teachers are overloaded vs idle — workload disputes are settled by impression.
4	MEDIUM	Single maxMarks per exam, not per subject Exam.maxMarks is one integer applied to all subjects. An exam where theory is /80 and practical is /20 cannot be represented; percentages and pass thresholds distort for any non-uniform exam.
5	MEDIUM	Leaderboard is hand-maintained Leaderboard entries are written manually by management and never recomputed from marks — standings go stale the moment a new exam is entered, and a wrong rank shown to guardians is a credibility hit.
6	LOW	No staff-circular acknowledgement Announcements to staff have no read receipt ("12 of 15 acknowledged"), so accountability for circulars remains verbal.
7	LOW	No structured classroom-observation register staff_remarks is free text; appraisal season needs a rubric with history per teacher.

#	Severity	Issue
8	LOW	No inspection pack / statutory registers DEO/board visits need printable attendance registers, enrollment-by-category and teacher lists as one bundle; today each is assembled by hand.

D. Teacher perspective — daily workflow

#	Severity	Issue
1	HIGH	Offline queue covers attendance only OfflineQueueService queues attendance writes, but marks entry, homework and remarks fail outright on flaky networks. Losing a class's marks during exam week (typed once, network drop, gone) is the single most app-abandoning failure mode for teachers. Generalise the enqueue/syncAll pattern.
2	MEDIUM	Offline state is invisible on most screens Only attendance and the two login screens watch connectivity. Everywhere else a queued/failed save renders exactly like a successful one — teachers cannot tell if their work is on the server.
3	MEDIUM	No leave-balance concept Teachers apply for leave with no view of quota vs used, and approvers approve blind. Quota in settings plus a ledger over approved leave_applications closes it.
4	MEDIUM	Approved leave does not nudge substitution Approving a teacher's leave and assigning a substitute are deliberately separate steps, but nothing reminds the coordinator if the second step is forgotten — the failure surfaces as an untaught class at the bell.
5	MEDIUM	Marks entry has no speedups No auto-advance to next student, no inline max-marks validation while typing, no CSV import. During deadline week this is the highest-friction screen in the app.
6	LOW	No period-swap workflow Teacher↔teacher swaps happen via the coordinator off-app; the substitution infrastructure could carry them.
7	LOW	No private student notes Everything a teacher writes lands in guardian-visible or staff-shared remark streams; there is no "for my eyes" note (e.g. sensitive home-situation context).
8	LOW	No draft state — edit re-notifies Homework/announcements post immediately; fixing a typo means delete + repost, which fans out notifications again and trains guardians to ignore them.

E. Guardian perspective — the parent experience

#	Severity	Issue
1	HIGH	No downloadable fee receipt Gapless receipt numbers are generated server-side, but guardians have no UI to view or download a receipt PDF. Every March (80C tax season) this becomes a front-office queue. The PDF pipeline already exists for report cards.
2	HIGH	No automatic absence alert When a child is marked absent, the guardian learns of it only if the teacher manually taps the per-student WhatsApp button. The safety-critical "your child did not reach school" push is one small Cloud Function over attendance writes — the highest-value missing alert in the app.
3	MEDIUM	No holiday calendar view calendar_events data exists; guardians have no screen for it. "Is school open tomorrow?" remains a phone call.
4	MEDIUM	No child timetable view The timetable collection knows the child's subjects per day, but guardians cannot see it — the daily "pack-the-bag" need.

#	Severity	Issue
5	MEDIUM	Roll number still used as child identity in messages Guardian-facing messages reference the roll number. Rolls get reassigned across years; the stable admissionId exists but messages have not switched to it — a misdirected fee or absence message names the wrong child.
6	MEDIUM	No second-guardian access One phone number per child: father OR mother. No invite flow for a second guardian, which in practice means shared credentials (and OTP lockout when the phone changes hands).
7	MEDIUM	Guardian correction requests lack a staff signal (verify) Guardians can submit detail corrections, but no badge/notification appears for staff — submissions sit unseen until someone happens to open that student's record.
8	LOW	No class-average context on marks A lone "65/100" answers nothing; an anonymous per-exam-subject average gives it meaning at near-zero privacy cost.
9	LOW	Leaderboard standing computed but never shown leaderboard_service data exists; no guardian UI surfaces the child's standing.
10	LOW	No exam syllabus or countdown Exams carry no "Ch 1–4" syllabus field and no reminder push as dates approach.

F. Data quality & compliance (residual)

#	Severity	Issue
1	MEDIUM	Class-name canonicalisation is still heuristic class_name_utils.dart exists, but spaces↔underscores / split('-') conventions appear across rules and services. "Class 9 - A" vs "Class 9-A" vs "9A" can mismatch attendance keys, classIds and fee lookups. Audit that every path routes through the one util (verify).
2	MEDIUM	Retention exists but is manual purgeOldData is a callable the owner must remember to invoke. Notifications, audit logs and deleted_students tombstones (which retain guardian email/phone) grow until then. Schedule it (onSchedule) instead.
3	MEDIUM	Consent gate scope (verify) Consent infrastructure is substantial (consent_service, consent_gate, parental_consent_flow) and gates WhatsApp sends. Confirm whether storing/processing a NEW minor's data is also blocked pending consent, as DPDP expects, or only the messaging path.
4	MEDIUM	Consecutive-absence streak inflates across unmarked days Unmarked days are skipped rather than breaking the streak, so a streak can span gaps when attendance simply wasn't taken — the coordinator dashboard then flags the wrong children.
5	LOW	Duplicate-roll guard on student move (verify) Roll-collision checking is confirmed at add time; verify the edit/move path can't land two students on one roll in a section.
6	LOW	17 bare int.parse sites remain Down from 33, but each is a latent crash on malformed Firestore data. Sweep to int.tryParse with defaults.
7	LOW	Attendance date keys not zero-padded YYYY-M-D keys ('2026-6-4') are internally consistent but break lexicographic ordering in any export or future query-by-range.
8	LOW	AppLogger PII discipline (verify) Confirm release builds never log emails/phones/marks — friendlyAuthError now logs e.message via AppLogger; make sure that channel stays out of release logs or scrubs PII.

G. Recommended order of attack

1. **Deploy what you've built** — claims backfill → syncUserClaims → storage.rules → firestore.rules → functions; until then most of your security work is theoretical (A1).

2. **Staging project + CI** — stop testing against live data; gate analyze/tests/rules-tests (A2, A3).
3. **Notification tap routing + absence auto-alert** — two small changes that multiply the value of the push pipeline for every role (A5, E2).
4. **Guardian fee receipts** — existing PDF + receipt infra, pure UI work, seasonal demand spike (E1).
5. **Extend offline queue to marks** — removes the worst teacher data-loss scenario (D1).
6. **Cash reconciliation + expense tracking** — turns the fee module into the owner's actual books (B1, B2).
7. **Exam analytics for the principal** — confirmed gap, data already stored (C1).
8. **Finish i18n (7 screens) and the catch({}) sweep** — small, mechanical, overdue (A7, B6).

Totals: 59 open issues — 2 critical, 10 high, 29 medium, 18 low. Generated from static analysis of main @ 9a7b85b; items marked (verify) need a quick manual confirmation.